WeConnect 2.0 — Retest Report

Independent verification of the reported fixes

Prepared for	Lighthouse Communities Foundation
Date	20 October 2026
Source retested	current `dev` of all 18 repositories, plus live `api-dev`

1. Summary

Outcome	Count	Findings
Verified fixed	3	WC-011, WC-130, WC-095 (for ordinary accounts)
Partially fixed / improved	7	WC-131, WC-129, WC-068, WC-073, WC-133, WC-134, WC-122
Still present	16	WC-084, WC-088, WC-079, WC-105, WC-128, WC-013, WC-004, WC-121, WC-112, WC-023, WC-116, WC-126, WC-125, WC-123, WC-089, WC-074

The two S1 breaches and nine further write-side items were re-tested at runtime on a rebuilt isolated stack (section 5); WC-084 is confirmed present and WC-095 confirmed fixed for ordinary accounts.

2. Verified fixed

- **WC-011** — the client-side auth guard is no longer hardcoded `true`; it is derived from the credentials. Confirmed in every frontend app.
- **WC-130** — the stored-XSS sink is gone. No `dangerouslySetInnerHTML` or `innerHTML` assignment remains anywhere in the frontend.
- **WC-095** (S1, cross-centre invoice) — the invoice API now has a centre-scope check. It exempts `System Manager`, but the live accounts no longer hold that role, so the check now applies to them. Confirmed at runtime on the isolated stack: a non-`System Manager` account is refused with HTTP 403 (section 5).

3. Partially fixed

- **WC-131** — the reset OTP is now drawn with a cryptographic generator (`secrets.randbelow`). It is still a four-digit code, so the space is 9000 values.
- **WC-129** — the key is no longer hardcoded in a source file, but the live key is still committed in `.env`, `.env.prod` and `.env.uat`. It needs rotating and purging from history, since the repository was public.
- **WC-068** — the `youth_skilling` API spec endpoints now require authentication; the `batch_management` spec is still served to anonymous callers.
- **WC-073** — the live accounts no longer hold `System Manager`: a real improvement. But the code still bypasses permissions at the same number of sites, so the model is now enforced inconsistently rather than centrally (see the Remediation Plan).
- **WC-133** — a React error boundary now exists in two of nine apps; the other seven still blank out on any component fault.
- **WC-134** — 204 images without `alt`, down from 264.
- **WC-122** — mass assignment is materially reduced: 23 of 28 sites now carry an allowlist guard (was about ten), and `add_interest` rejects undeclared fields at runtime. Five sites remain unguarded (section 5).

4. Still present

Verified in the current source or live, on 20 October:

- **WC-084** (S1) — `close_batch` still has no centre or permission check.
- **WC-088** — the `id = json.loads(id)` typo is still at both sites.
- **WC-079**, **WC-105** — the permission bypass is unchanged: 322 `ignore_permissions` sites and 66 `System Manager` references in backend code.
- **WC-128** — the password-reset flow still logs the OTP to the browser console. We had recorded this as fixed on 8 October; on re-reading the current code it is not, and we are correcting that here.
- **WC-013**, **WC-004** — the API secret is still kept in `localStorage` (15 sites) and 19 `.env` files are still committed.
- **WC-121**, **WC-112**, **WC-023**, **WC-116** — CORS reflects any origin, no security headers are sent, tracebacks still appear in error bodies, and the session is seven days. All still live on `api-dev`. If these are fixed in a branch not yet deployed there, tell us which environment to retest.

5. Runtime re-confirmation (isolated stack)

Rebuilt from the current `dev` source and seeded with synthetic data. The two critical write breaches were tested end to end.

- **WC-084** (S1) — **still present, confirmed at runtime.** A Skilling Partner account permitted only for East and West centres closed a batch owned by North Centre: the API answered *"Batch closed successfully."* `close_batch` applies no centre check.
- **WC-095** (S1) — **fixed for ordinary accounts, confirmed at runtime.** A non-`System Manager` account permitted only for East and West, raising a North invoice, was refused with HTTP 403, *"You do not have permission to raise this invoice."* The breach now reproduces only for an account that holds `System Manager`; the live accounts no longer do, so they are protected. The fix is therefore conditional on account-role configuration rather than enforced for every caller — if any privileged account keeps `System Manager`, the breach returns for it.

We also re-ran the full write-side probe battery. The synthetic accounts hold `System Manager` by necessity, so role-gating counts are an upper bound; the data, validation and state results are faithful.

- **WC-126** — **still present.** Every status transition is accepted: Skilling Invoice 30/30, Skilling Batch 72/72. No state machine.
- **WC-125** — **still present.** Five of twelve contradictory values stored without complaint (negative and inverted batch capacity, a 150% and a negative instalment percentage, a negative course cost). A future date of birth is now rejected — one axis improved.
- **WC-122** — **materially improved.** `add_interest` now rejects an undeclared field; 23 of 28 mass-assignment sites now carry an allowlist guard, up from about ten. Five remain unguarded.
- **WC-123** — **still present.** An account wrote a field on another user's record (one of the five unguarded sites).
- **WC-089**, **WC-074** — **still present.** Four endpoints answer a bad request with a 500 instead of a 400; `close_batch` returns 200 on failure.

Not cleanly re-run (the probe harness expects fields the current, stricter code now requires): WC-048, WC-035, WC-078, WC-115, WC-085. Status stands on source and earlier runtime evidence.